

GMX · SECURITY REVIEW

GMX

AutoCancel Updates.

A security review of AutoCancel Updates.

CLIENT	PROJECT	AUDITORS	AUDIT WINDOW	FINAL REPORT
GMX	AutoCancel Updates	Guardian	August 2 – August 2, 2024	August 9, 2024

§ 00

Contents.

15 pages — overview, confidence ranking, scope, 6 findings, disclaimer, and about Guardian.

§ 01	Overview	P. 03
§ 02	Confidence Ranking	P. 04
§ 03	Scope & Classifications	P. 05
	Files in Scope	P. 06
§ 04	Findings	P. 07
	Main Review · 6 findings	P. 08
§ 05	Disclaimer	P. 14
§ 06	About Guardian	P. 15

§ 01

Overview.

Guardian reviewed AutoCancel Updates across a single review round. The final report includes 2 Medium, 4 Low findings.

AUDIT FIRM	REPOSITORY
Guardian	gmx-io/gmx-synthetics
CLIENT	METHODOLOGY
GMX	Smart contract · Manual · Main Review
PROJECT	MAIN REVIEW COMMIT
AutoCancel Updates	052464a07c49
PREPARED BY	
Guardian	
AUDIT WINDOW	
August 2 – August 2, 2024	
FINAL REPORT	
August 9, 2024	

1.1 Confidence Ranking

5 / 5

Very High Confidence

Guardian assigns a Confidence Ranking of 5 out of 5, combining finding severity, remediation outcome, and the reviewer’s assessment of latent risk. The full scale is on the next page.

1	2	3	4	5
VERY LOW CONFIDENCE	LOW CONFIDENCE	MODERATE CONFIDENCE	HIGH CONFIDENCE	VERY HIGH CONFIDENCE

1.2 Findings at a Glance

SEVERITY	TOTAL	PENDING	ACK	PARTIAL	RESOLVED
Critical	0	0	0	0	0
High	0	0	0	0	0
Medium	2	0	2	0	0
Low	4	0	4	0	0
Informational	0	0	0	0	0
All severities	6	0	6	0	0

§ 02

Confidence Ranking.

Guardian assigns a project-level confidence score using the scale below. The ranking combines finding severity, remediation outcome, and the reviewer's assessment of latent risk.

CONFIDENCE RANKING	DEFINITION AND RECOMMENDATION	RISK PROFILE
5 Very High Confidence ASSIGNED	Codebase is mature, clean, and secure. No High or Critical vulnerabilities were found. Follows modern best practices with high test coverage and thoughtful design. Recommendation: code is highly secure at time of audit.	0 High/Critical findings and few Low/Medium severity findings.
4 High Confidence	Code is clean, well-structured, and adheres to best practices. Design patterns are sound and test coverage is strong. Recommendation: suitable for deployment after remediations; consider periodic review with changes.	0-1 High/Critical findings per engagement week and little to no Medium severity findings.
3 Moderate Confidence	Code is functional but shows gaps in defensive programming or test coverage. Recommendation: remediate the findings and re-review the changes before deployment.	Some High/Critical findings, with various Medium severity findings.
2 Low Confidence	Recurring issues suggest systemic gaps rather than isolated mistakes. Recommendation: remediate, then commission a follow-up review at a frozen commit.	Over 6 High and Critical findings across the engagement.
1 Very Low Confidence	The volume and severity of findings indicate the codebase is not ready for production. Recommendation: substantial rework, then a full re-review.	Over 12 High and Critical findings across the engagement.

§ 03

Scope & Classifications.

Guardian reviewed AutoCancel Updates in `gmx-io/gmx-synthetics`.

3.1 Severity Matrix

	IMP · HIGH	IMP · MED	IMP · LOW
LIK · HIGH	Critical	High	Medium
LIK · MED	High	Medium	Low
LIK · LOW	Medium	Low	Low

IMPACT · HIGH
Significant loss of assets, harm to a group of users, or core protocol functionality is disrupted.

IMPACT · MEDIUM
Small amount of funds can be lost, or ancillary functionality is affected. Users may experience reduced or delayed receipt.

IMPACT · LOW
Unexpected behavior in some functionality that is notable but does not meet the criteria for higher severity.

LIKELIHOOD · HIGH
Possible with reasonable assumptions that mimic on-chain conditions; cost is low compared to amount gained.

LIKELIHOOD · MEDIUM
Possible only in uncommon cases or requires a large amount of capital relative to disruption caused.

LIKELIHOOD · LOW
Unlikely to ever occur in production.

Files in Scope.

FILE	NSLOC	TOTAL
No files were recorded in scope.		

§ 04

Findings.

Grouped by round. Visible IDs reset by severity within each round, so a finding is named the same way in the report as it was in the channel it was written in.

ID	TITLE	CATEGORY	SEVERITY	STATUS	PAGE
MAIN REVIEW					
M-01	Orders Cannot Be Updated At Max AutoCancel Amount	DoS	MEDIUM	ACKNOWLEDGED	p. 8
M-02	Closed Positions With AutoCancel Orders	Logical Error	MEDIUM	ACKNOWLEDGED	p. 9
L-01	Lacking Zero Address Checks	Validation	LOW	ACKNOWLEDGED	p. 10
L-02	Compromised ConfigKeeper Can Arbitrage Impact Pool	Configuration	LOW	ACKNOWLEDGED	p. 11
L-03	Compromised ConfigKeeper Can Reset Holding Address	Configuration	LOW	ACKNOWLEDGED	p. 12
L-04	Compromised ConfigKeeper Can Liquidate All Positions	Configuration	LOW	ACKNOWLEDGED	p. 13

MEDIUM **M-01**

ACKNOWLEDGED

Orders Cannot Be Updated At Max AutoCancel Amount

CATEGORY DoS
LOCATION AutoCancelUtils.sol: 14
REVIEW Main Review

DESCRIPTION

When updating an order with the `OrderHandler.updateOrder` function, orders which were already present in the AutoCancel list are attempted to be re-added with the `updateAutoCancelList` function.

The AutoCancel list is a set, therefore no orders are duplicated. However as the `maxAutoCancelOrders` validation is performed in the `addAutoCancelOrderKey` function, `updateOrder` calls are DoS'd in the following circumstance:

- The account holds the `maxAutoCancelOrders` in their `autoCancelOrderList`
- Order A is an existing order which is in the `autoCancelOrderList`
- User attempts to update Order A, but wishes to update parameters other than the `autoCancel` value

As a result the user cannot update this order without removing it from the auto cancel list or removing other auto cancel orders.

RECOMMENDATION

Only call the `updateAutoCancelList` in the event that the order `autoCancel` value is changed from the existing value.

RESOLUTION

Status: Acknowledged.

MEDIUM **M-02**

ACKNOWLEDGED

Closed Positions With AutoCancel Orders

CATEGORY Logical Error
LOCATION Global
REVIEW Main Review

DESCRIPTION

The `syncAutoCancelOrderList` function relies on an account's open positions to collect the `autoCancel` orders which need to be synced.

However there may exist accounts where the position has been closed through the old contracts, and therefore `autoCancel` orders exist for that null position.

Additionally some of these `autoCancel` orders may only be present in the `autoCancel` list, and not in the `orderStore`, therefore requiring a sync. They should all be synced and removed from the list.

However these `autoCancel` orders cannot be synced as they do not belong to a position which is currently open for the account. Users may have their `autoCancel` orders go unsynced during the period of syncing, open their position again in the future, and have unsynced `autoCancel` orders which prevent their position from closing.

RECOMMENDATION

Consider adding a new function to target a specific `positionKey` instead of relying solely on the account's open positions with the `getAccountPositionKeys` function.

RESOLUTION

Status: Acknowledged.

LOW **L-01**

ACKNOWLEDGED

Lacking Zero Address Checks

CATEGORY Validation
LOCATION Config.sol: 83
REVIEW Main Review

DESCRIPTION

The `initOracleProviderForToken` function allows the keeper to initialize a provider. However, the provider has no validation on it and may be the zero address.

RECOMMENDATION

Add a zero address check on address provider.

RESOLUTION

Status: Acknowledged.

LOW **L-02**

ACKNOWLEDGED

Compromised ConfigKeeper Can Arbitrage Impact Pool

CATEGORY Configuration

LOCATION Config.sol: 101

REVIEW Main Review

DESCRIPTION

In the `setPositionImpactDistributionRate` function the `configKeeper` may assign any arbitrary `positionImpactPoolDistributionRate`, therefore if the config keeper is compromised they may drain the position impact pool by setting an excessively high rate and potential arbitrage this by depositing into the GM token market beforehand.

RECOMMENDATION

Consider adding a maximum impact pool distribution rate to the `setPositionImpactDistributionRate` function.

RESOLUTION

Status: Acknowledged.

LOW **L-03**

ACKNOWLEDGED

Compromised ConfigKeeper Can Reset Holding Address

CATEGORY Configuration

LOCATION Config.sol: 383

REVIEW Main Review

— DESCRIPTION

The `Keys.HOLDING_ADDRESS` key is allowed in the `_initAllowedBaseKeys` function, therefore the a compromised config keeper may re-assign the holding address to their own account or assign it to the zero address.

If the holding address is assigned to the zero address, all instances where the holding address is used will lead to a DoS, which can re-enable several risk-free trade vectors which the holding address solves.

— RECOMMENDATION

Consider only allowing the holding address to be updated by the config keeper if it is not assigned. And allow the holding address to be configured by the more trusted timelock address.

— RESOLUTION

Status: Acknowledged.

LOW **L-04**

ACKNOWLEDGED

Compromised ConfigKeeper Can Liquidate All Positions

CATEGORY Configuration

LOCATION Config.sol: 413

REVIEW Main Review

— DESCRIPTION

In the `_initAllowedBaseKeys` function the `MIN_POSITION_SIZE_USD` and `MIN_COLLATERAL_FACTOR` keys are allowed as a value that the config keeper may assign, as a result a compromised config keeper may assign an exceedingly high minimum position size or minimum collateral factor and cause all GMX positions to be liquidated.

The config keeper could short the GMX token in order to profit from such a catastrophe.

— RECOMMENDATION

Consider moving these configurations to the more trusted time lock.

— RESOLUTION

Status: Acknowledged.

§ 05

Disclaimer.

This report is not, nor should be considered, an "endorsement" or "disapproval" of any particular project or team. This report is not, nor should be considered, an indication of the economics or value of any "product" or "asset" created by any team or project that contracts Guardian to perform a security assessment. This report does not provide any warranty or guarantee regarding the absolute bug-free nature of the technology analyzed, nor do they provide any indication of the technologies proprietors, business, business model or legal compliance.

This report should not be used in any way to make decisions around investment or involvement with any particular project. This report in no way provides investment advice, nor should be leveraged as investment advice of any sort. This report represents an extensive assessing process intending to help our customers increase the quality of their code while reducing the high level of risk presented by cryptographic tokens and blockchain technology.

Blockchain technology and cryptographic assets present a high level of ongoing risk. Guardian's position is that each company and individual are responsible for their own due diligence and continuous security. Guardian's goal is to help reduce the attack vectors and the high level of variance associated with utilizing new and consistently changing technologies, and in no way claims any guarantee of security or functionality of the technology we agree to analyze.

The assessment services provided by Guardian is subject to dependencies and under continuing development. You agree that your access and/or use, including but not limited to any services, reports, and materials, will be at your sole risk on an as-is, where-is, and as-available basis.

Cryptographic tokens are emergent technologies and carry with them high levels of technical risk and uncertainty. The assessment reports could include false positives, false negatives, and other unpredictable results. The services may access, and depend upon, multiple layers of third-parties.

Notice that smart contracts deployed on the blockchain are not resistant from internal/external exploit. Notice that active smart contract owner privileges constitute an elevated impact to any smart contract's safety and security. Therefore, Guardian does not guarantee the explicit security of the audited smart contract, regardless of the verdict.

§ 06

About Guardian.

Guardian is a smart contract security firm. Every engagement is worked by two independent teams competing on the same scope, each with its own tooling and methods, so no single reviewer's blind spot survives.

\$45B+DIGITAL ASSETS UNDER
REVIEW**200+**

ENGAGEMENTS COMPLETED

500+CRITICAL & HIGH FINDINGS
REPORTED

Reach us at audits@guardianaudits.com.